

UTHM

اونيۏرسيتي تون حسين عون مليسيا

Universiti Tun Hussein Onn Malaysia

WEB SECURITY

BIS20303

SECTION 1

SEMESTER 1 SESSION 2026/2027

GROUP 2

LAB 2:

EXPLORING OWASP & WEB SECURITY RISK

PREPARED FOR:

ENCIK KHAIRUL AMIN BIN MOHAMAD SUKRI

PREPARED BY:

NAME	MATRIX NUMBER
MUHAMMAD SYAZWAN BIN SA'DAN	CI250079
AHMAD IRWAN NASUHA BIN SHUKRI	CI250084
MUHAMMAD FARIS HAKIMI BIN MOHD SHARIFF	CI250125
MUHAMMAD IRHAM AIDID BIN MOHD SIDI	DI250014

OWASP Top 10 Risk Analysis and Case Study

Chosen Vulnerability: Broken Access Control

1.0 INTRODUCTION TO OWASP

1.1 What is OWASP and why is it important

OWASP stands for Open Worldwide Application Security Project. It is a non-profit organisation that helps people learn about software security. OWASP provides free tools, guides, and learning materials to help developers build safer applications (OWASP Foundation, n.d.-a).

1.2 OWASP Top 10

The OWASP Top 10 lists the ten most common and important security risks in web applications. It helps developers understand security problems and find ways to protect their websites. It is a useful starting point, but it does not cover every security issue. The latest released version is OWASP Top 10 2025 vulnerabilities (OWASP Foundation, 2025a).

1.3 How often is the list updated

OWASP does not update the list every year. Recent versions were released in 2017, 2021, and 2025, which were four years apart. The list changes based on vulnerability data and changes in application security. Some categories may be renamed, combined, or moved to a different position (OWASP Foundation, 2025a, 2025b).

2.0 DETAILED ANALYSIS OF BROKEN ACCESS CONTROL

2.1 Risk Description

This analysis of risk (BAC) is a security problem that happens when a website does not properly check what users are allowed to access. Because of this, a user may be able to view, change, or delete information that belongs to someone else. For example, a student might be able to view another student's examination results by changing the ID in a website URL (Security Journey/HackEDU Team, 2026) .

2.2 How It Happens

Insecure IDs: Some websites use IDs in URLs to identify users or their data. If the website does not check whether the user has permission to access that data, the attacker might change the ID to view another user information. For example, changing an account ID from 1001 to 1002 might allow access to another person's account details.

Forced Browsing: This happens when an attacker enters a restricted page's URL directly instead of following the normal steps on the website.

2.3 Prevention

Implement Deny-by-Default Access Controls: The website should block access unless the user has the correct permission. For example, only administrators should be allowed to access administrative functions.

Enforce the Principle of Least Privilege: Each user should only have the permissions needed for their role. For example, students should be able to view their own results but should not be allowed to change their grades.

Use Centralized, Server-Side Authorization Checks: The server should check a user's permissions whenever they try to access protected information or perform an action. Developers should not rely only on hiding buttons or pages because users may still try to access them directly.

3.0 BREACH THAT REFLECTS OUR SELECTED RISK IS: OPTUS DATA BREACH (AUSTRALIA, 2022)

4.0 RELATION ON THE OPTUS DATA BREACH

4.1 What happened in the breach

On 22 September 2022, Optus announced that more than 9.5 million Australians had been affected by the incident. In the Optus data breach, attackers accessed customers personal information such as full names, phone numbers, dates of birth, and email addresses.

4.2 How does the breach relate to Broken Access Control

Its is related because the API did not properly check if the person had permission to access the requested information. As a result, attackers could access private customer data. This is known as Insecure Direct Object Reference (IDOR).

4.3 What could have prevented the attack

1. Proper authentication and authorization: Optus should have checked every API request to ensure that users could only access information they were allowed to see.

2. Use of secure identifiers: Using unpredictable identifiers could make it harder for attackers to guess customer records, although authorization checks are still necessary.

3. Disable unused APIs: Unused APIs should be removed or restricted to reduce security risks.

5.0 REFERENCES

[1] Dark Reading. (2022, September 27). *FBI helping Australian authorities investigate massive Optus data breach: Reports*. https://www.darkreading.com/cyberattacks-data-breaches/fbi-helping-australian-authorities-investigate-massive-optus-data-breach-reports

[2] OWASP. (n.d.). *Broken access control.* https://community.owasp.org/Broken_Access_Control

[3] Security Journey/HackEDU Team. (2026, April 10). *Broken access control: Definition, examples & prevention (OWASP #1)*. https://www.securityjourney.com/post/broken-access-control-definition-examples-and-how-to-defend-against-it